Microsoft Purview GDPR Compliance Program

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft Purview GDPR Compliance Program 5

What you get . . . 5

What this delivers . . . 5

The standard deployment model . . . 5

Outcome . . . 5

1. Solution Overview — Microsoft Purview GDPR Compliance Program 6

What this solution is . . . 6

Why this matters . . . 6

How it works . . . 7

What this does *not* do (limitations) . . . 8

Naming convention (used in every doc and script) . . . 8

The standard deployment model . . . 9

2. Requirements Guide — Microsoft Purview GDPR Compliance Program 9

2.1 Compliance licensing for the GDPR assessment + mapped controls . . . 9

2.2 Least-privilege Compliance Manager + Purview roles (separation of duties) . . . 9

2.3 In-scope GDPR assessment template selected . . . 10

2.4 Scope: EU personal data, workloads, and the classification intent . . . 10

2.5 Data-subject-request (DSR) method decided . . . 10

2.6 Compliance, privacy, records & legal stakeholders + ROPA source . . . 10

2.7 Audit logging enabled (accountability evidence) . . . 11

2.8 Pilot scope and change control . . . 11

Checklist . . . 11

Global Requirements — Microsoft Purview Solutions 12

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 12

2. Purview roles (least-privilege) and portal access . . . 12

3. Security & Compliance PowerShell + Graph toolchain . . . 12

4. Data sources & scope in scope . . . 13

5. Compliance, records, privacy & legal stakeholders . . . 13

6. A pilot scope and change control . . . 13

3. Implementation Guide — Microsoft Purview GDPR Compliance Program 14

Step 1 — Baseline the posture and roles (Assess) . . . 15

Step 2 — Design the scope and the article-to-control map (Design) . . . 15

Step 3 — Create the pilot GDPR assessment (Configure) . . . 16

Step 4 — Build the action plan and evidence register . . . 16

Step 5 — Configure the personal-data protection controls (pilot in simulation/test) . . . 16

Step 6 — Pilot and tune (the audit gate) . . . 17
Step 7 — Wire the DSR (data-subject-request) method . . . 17
Step 8 — Promote high-impact controls to enforce (after the gate) . . . 17
Step 9 — Validate . . . 17
Step 10 — Report and expand . . . 18
5. Testing Guide — Microsoft Purview GDPR Compliance Program 18
Test 1 — GDPR assessment created and scored . . . 18
Test 2 — Roles separated (least privilege) . . . 18
Test 3 — Article-to-control map complete . . . 19
Test 4 — Personal-data label published and applies . . . 19
Test 5 — Auto-labeling simulation matches EU personal data . . . 19
Test 6 — DLP is auditing (before the gate) . . . 19
Test 7 — DLP enforces (after the gate) . . . 19
Test 8 — Retention (storage limitation) applied . . . 19
Test 9 — DSR method locates a data subject's data . . . 19
Test 10 — Audit and coverage evidence . . . 20
Test 11 — Posture report produced . . . 20
Pass/fail gate . . . 20
6. Troubleshooting Guide — Microsoft Purview GDPR Compliance Program 20
The GDPR assessment template isn't available in Compliance Manager . . . 20
Compliance Score doesn't move / improvement actions don't auto-test . . . 21
The personal-data label doesn't appear for pilot users . . . 21
Auto-labeling simulation shows nothing (or the wrong items) . . . 21
DLP records nothing in audit . . . 21
DLP blocks legitimate work after enforce . . . 22
A DSR (subject rights request) returns nothing / too much . . . 22
Retention deletes too much or nothing (storage limitation) . . . 22
Role separation looks wrong (HR/privacy-sensitive roles) . . . 22
Evidence report is empty or partial . . . 23
PowerShell can't connect or a cmdlet is missing . . . 23
7. Best Practices — Microsoft Purview GDPR Compliance Program 23
8. Deliverables Summary — Microsoft Purview GDPR Compliance Program 24
Documentation . . . 24
PowerShell scripts . . . 25
What the buyer receives . . . 25
Outcome . . . 26

Appendix A — PowerShell Scripts 27

Executive Summary — Microsoft Purview GDPR Compliance Program

White-label · Purview Solutions

"Are we GDPR-compliant?" has no defensible answer without a scored control map and the evidence behind it. GDPR sets principles (Art. 5), data-subject rights on a one-month clock (Art. 15/17/20), security of processing (Art. 32), and accountability (Art. 5(2)) — but scattered across a Microsoft 365 tenant, those obligations are invisible until a complaint, an audit, or a breach makes them urgent.

This is a complete, deploy-it-in-order package for standing up a **GDPR-aligned compliance program inside Microsoft Purview**: it maps each in-scope GDPR obligation to the Purview control that evidences it, scores the program in **Compliance Manager** (the **GDPR assessment template**), wires a **data-subject-request (DSR)** method that answers access/erasure/portability requests, and centralizes the **evidence** — owners, implementation status, test status, and proof — that makes the posture defensible. It is written for an administrator with no prior Purview experience.

What you get

• A plain-language Solution Overview of the GDPR program — Compliance Manager scoring, the article-to-control map, the DSR method, and the evidence register — and how they fit together.

• A Requirements Guide with verify / implement-if-missing for every GDPR-specific prerequisite.

• An Implementation Guide of precise, ordered steps in the Microsoft Purview (and Priva) portal.

• Five PowerShell scripts for posture discovery, object validation, cross-control evidence reporting, safe remediation of gaps, and a pilot-scope group builder.

• Testing and Troubleshooting guides for a confident rollout.

What this delivers

A named, reusable program — a GDPR assessment, an article-to-control map, an action plan, an evidence register, a personal-data label/DLP/retention control set, and a DSR runbook — deployed on the assess-design-configure-pilot model, with a mandatory DLP audit gate before any control enforces, a tested DSR method, and a documented rollback.

The standard deployment model

Assess → **Design** → **Configure** → **Pilot (simulate)** → **Validate** → **Expand.**

Outcome

A GDPR-aligned Purview program — obligations mapped, scored, and evidenced; personal-data protection piloted before it enforces; data-subject requests answerable on the clock — configured, validated, and defensible. GDPR applicability, lawful basis, records of processing, DPIA outcomes, and evidence adequacy remain compliance, privacy, and legal determinations; this program supplies the technical method and the proof, not the ruling.

1. Solution Overview — Microsoft Purview GDPR Compliance Program

What this solution is

This solution stands up a **GDPR-aligned compliance program inside Microsoft Purview**: it maps the **EU General Data Protection Regulation** obligations to the **Microsoft Purview** technical controls that satisfy them, measures the program with **Compliance Manager**, wires the **data-subject-request (DSR) method** that answers access/erasure/portability requests, and produces the **evidence** — owners, implementation status, test status, and proof — that makes the posture **defensible**. The output is a scored, control-by-control GDPR program with an article-to-control map, an improvement- action plan, an evidence register, a DSR runbook, and a posture report — configured, piloted where high-impact, and validated.

It is the **program umbrella**, not a single control. It uses **Compliance Manager** (the **GDPR** assessment template) to score, and it maps each obligation to the Purview capability that evidences it — **Audit**, **sensitivity labels**, **Data Loss Prevention (DLP)** over **EU personal-data sensitive-information types**, **data lifecycle / retention** (the storage-limitation principle), **sensitive information types**, and (where scoped) **Insider Risk Management**, **Communication Compliance**, and **eDiscovery / content search** as the DSR locate method. It uses only the **Microsoft Purview portal** (`purview.microsoft.com`), **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party tooling.

> ***This is a program, not a legal determination.*** *Purview and Compliance Manager give you the **measurement, control mapping, and evidence**. Whether the GDPR **applies** to a given processing activity, the **lawful basis** you rely on, your **records of processing (Art. 30)** content, the outcome of a **Data Protection Impact Assessment (Art. 35)**, retention **schedules**, and whether the collected evidence **satisfies** a supervisory authority are **compliance, privacy, records, and legal determinations** — this solution provides the technical method and the proof, not the ruling.*
>
> ***Distinct from the GDPR PII DLP pack.*** *A GDPR **DLP pack** configures a *specific* control (DLP over EU personal-data types). **This program sits above it**: it maps *all* the in-scope GDPR obligations to Purview controls, scores the whole program in Compliance Manager, wires the DSR workflow, and collects the cross-control evidence. It **references** the individual technical controls; it does not re-implement each one — where an obligation needs a high-impact technical change (a new DLP, label, or retention policy), that change is **piloted in simulation/test** under its own change control, and this program **evidences** that it is in place.*

Why this matters

- **"Are we GDPR-compliant?" has no defensible answer without a scored control map.** GDPR is a set

of principles and rights (Art. 5 principles; Art. 15–22 data-subject rights; Art. 25 privacy-by-design; Art. 30 records of processing; Art. 32 security of processing; Art. 33–34 breach notification). Compliance Manager turns the technical subset into a **measured score** with a per-control status and evidence, so gaps are **visible, owned, and tracked** instead of discovered in a complaint, an audit, or a breach.

• **DSRs are an operational obligation with a clock.** Access, erasure, and portability requests

(Art. 15/17/20) must be answered within **one month**. Without a defined **locate-review-produce** method they become a scramble. This program wires the **DSR runbook** — Priva Subject Rights Requests where licensed, or Purview **eDiscovery / content search** as the locate method — so a request is a routine, not a fire drill.

• **Evidence is what a supervisory authority (or a controller audit) asks for.** A posture is only

defensible if each control carries **who owns it, whether it is implemented, when it was tested, and the proof**. This program centralizes that record — audit-log configuration, DLP over EU personal data, labels, retention — so producing it is repeatable.

• **Control mapping means you evidence once and score many.** One well-implemented control — unified

audit logging, say — satisfies GDPR Art. 32/33 *and* maps across ISO 27701, NIST, and your internal baseline in Compliance Manager's **shared-control** model. You fix once and the score updates in every assessment that shares the control.

• **Applicability, lawful basis, and adequacy are not technical calls.** *Which* obligations apply,

the **lawful basis**, the **ROPA** content, DPIA outcomes, and whether the evidence is **sufficient** are **compliance/privacy/legal** determinations. This program supplies the configuration method and the evidence; it does not decide sufficiency.

How it works

1. **Baseline the posture (Assess).** Confirm licensing and the Compliance Manager role groups,

capture the current **Compliance Score** and technical-control state (audit on/off, DLP/label/retention presence, EU sensitive-information-type usage), and record the readiness snapshot (`GDPR Roles – Separation Evidence`).

1. **Design the assessment, scope, and article map (Design).** With compliance/privacy/legal

stakeholders, confirm the **GDPR assessment template**, the **scope** (workloads holding EU personal data, the systems in scope), the **DSR method**, and the **article-to-Purview control map** (`GDPR Control Map – Articles`, `GDPR Scope – Record`). Applicability, lawful basis, and ROPA content are the stakeholders' determinations.

1. **Configure roles, assessment, plan, evidence, and DSR (Configure).** Set least-privilege role

separation, create the pilot **GDPR assessment**, build the **action plan** and **evidence register**, enable **automatic testing** for eligible actions, and wire the **DSR runbook** — piloting any new high-impact control (a DLP, label, or retention policy) in **simulation/test** first.

1. **Validate (Validate).** Confirm the technical evidence behind each mapped control — audit on,

DLP over EU personal data present, labels published, retention scoped — with explicit **pass/fail gates**, and run a **test DSR** end to end.

1. **Report and expand (Expand).** Produce the **posture report**, expand the assessment to the full

program, and run the maintenance cadence. Enforce high-impact controls only after their pilot passes; keep a documented rollback.

What this does *not* do (limitations)

• **Licensing-gated.** The **GDPR assessment template** and premium capabilities (auto-labeling at rest, endpoint DLP, Audit Premium, DSPM, Insider Risk, Communication Compliance) require **Microsoft 365 E5** or the **E5 Compliance** add-on; **Priva Subject Rights Requests** requires **Microsoft Priva** licensing. Availability is plan-/tenant-dependent — **verify your licensing/tenant**; the portal is evolving and paths may differ.

• **Compliance Manager is portal-driven.** Assessments, improvement actions, evidence upload, and the authoritative score are managed in the **Purview portal**. Compliance Manager does **not** expose a broad public PowerShell/Graph API to create assessments or set action status; the provided scripts assess **readiness, roles, and the technical evidence** behind the controls and structure the plan/evidence artifacts — they do **not** replace the portal.

• **Automatic testing is partial.** Only **eligible** actions auto-test from Microsoft 365 signals; others need manual implementation/test and uploaded evidence. Availability is plan/action-dependent — verify.

• **Legal determinations are deferred.** GDPR applicability, lawful basis, ROPA (Art. 30) content, DPIA (Art. 35) outcomes, retention schedules, and evidence adequacy are **compliance/privacy/legal** determinations, not outputs of this tool.

• **No secrets in automation.** The scripts use interactive modern-auth sign-in; they never embed credentials.

Naming convention (used in every doc and script)

Every artifact is named `<Purpose> – <Scope> – <Stage>` and reused verbatim across docs, scripts, and the portal. The standard set:

Artifact	Name
GDPR assessment (pilot)	`GDPR Assessment – Regulation – Pilot`
GDPR assessment (production)	`GDPR Assessment – Regulation – Production`
Article → control map	`GDPR Control Map – Articles`
Improvement-action plan (pilot)	`GDPR Action Plan – Pilot`
Evidence register	`GDPR Evidence – Register`
Automatic-testing setting	`GDPR Automatic Testing – Setting`
Score / posture report	`GDPR Posture – Report`
Role-separation evidence snapshot	`GDPR Roles – Separation Evidence`
Scope / owners record	`GDPR Scope – Record`
Sensitivity label (personal data)	`Sensitivity Label - Personal Data (GDPR) - All Users`

Artifact	Name
DLP policy (EU personal data)	`DLP Policy - EU Personal Data - Audit` (→ `... - Enforce` at the gate)
Auto-labeling policy	`Auto-Label - EU Personal Data - Pilot`
Retention label (storage limitation)	`Retention Label - Personal Data - Storage Limitation`
DSR access search (content search method)	`DSR - Data Subject Access - Search`

The standard deployment model

> *Baseline the posture → design the assessment, scope, article map, and DSR method with compliance/privacy/legal → configure roles (separation), create the pilot assessment, build the action plan and evidence register, enable automatic testing, wire the DSR runbook → validate the technical evidence behind each control (piloting any new high-impact control in simulation/test) and run a test DSR → report the posture → expand to the full program and run the maintenance cadence. Pattern:* ***Assess → Design → Configure → Pilot (simulate/test) → Validate → Expand*** *— GDPR applicability, lawful basis, ROPA content, DPIA outcomes, and evidence adequacy deferred to compliance/privacy/legal at every step.*

2. Requirements Guide — Microsoft Purview GDPR Compliance Program

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites are in `global-requirements-purview.md` — this guide names the **GDPR-specific** licensing, roles, scope, and inputs; it does not repeat the six.

2.1 Compliance licensing for the GDPR assessment + mapped controls

Description: Licensing that surfaces **Compliance Manager**, the **GDPR assessment template**, and the technical controls this program maps. Compliance Manager and the Microsoft 365 data-protection baseline assessment ship broadly; the **GDPR template**, **premium assessment templates**, **auto-labeling at rest**, **endpoint DLP**, **Audit Premium**, **DSPM**, **Insider Risk Management**, and **Communication Compliance** require **Microsoft 365 E5** or the **E5 Compliance** add-on. **Priva Subject Rights Requests** (the managed DSR workflow) requires **Microsoft Priva** licensing. **Why:** The GDPR template and the mapped premium controls will not appear without the right plan; availability is plan-/tenant-dependent and the portal evolves — **verify your licensing/tenant**. **Verify:** Microsoft 365 admin center → **Billing** → **Licenses**; in Purview → **Compliance Manager** → **Assessment templates** confirm **GDPR** is available; run `GDPR-Discovery.ps1`. **Implement:** Assign the required plan/add-on before starting; if a template or control is absent, confirm the plan rather than assuming the tenant lacks the capability.

2.2 Least-privilege Compliance Manager + Purview roles (separation of duties)

Description: The operator holds only the roles the program needs — **Compliance Manager Assessors / Contributors** for the assessment, **Compliance Administrator** (or **Information Protection Admin** + **Data Loss Prevention** roles) for the mapped controls, **Audit** roles for the audit evidence, and (where scoped) **eDiscovery** / **Subject Rights Request** roles for the DSR method. HR/privacy-sensitive capabilities (Insider Risk, Communication Compliance) are **separated** from the general operator. **Why:** Purview uses fine-grained role groups; least-privilege and **role separation** are both a control and evidence for GDPR accountability (Art. 5(2)/32). Global Administrator alone is not the least-privilege choice. **Verify:** `https://purview.microsoft.com` → **Settings** → **Roles and scopes** → **Role groups**; confirm membership and that sensitive roles are held by separate owners. Run `GDPR-Discovery.ps1` (role report). **Implement:** Assign the least-privilege role groups under change control; capture the separation as `GDPR Roles – Separation Evidence`.

2.3 In-scope GDPR assessment template selected

Description: The **GDPR assessment** to work against — the built-in **GDPR** template (and any overlay the organization runs, e.g. **ISO 27701** where entitled) — chosen with compliance/privacy. **Why:** The assessment defines the improvement actions, the score, and the evidence structure; the program is built around the chosen template. **Verify:** Purview → **Compliance Manager** → **Assessments**; confirm the GDPR template is available to add. Run `GDPR-Discovery.ps1`. **Implement:** Confirm the template with compliance/privacy stakeholders before creating the pilot assessment (Implementation Step 3).

2.4 Scope: EU personal data, workloads, and the classification intent

Description: The **workloads and data sources** holding **EU personal data** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints), and the **EU personal-data sensitive-information types** (e.g. **EU National Identification Number**, **EU Passport Number**, **EU Driver's License Number**, **EU Tax Identification Number**, **EU Debit Card Number**, **EU Social Security Number or Equivalent ID**) that drive labels and DLP. **Why:** Purview policies key off the in-scope workloads and the sensitive-information types; the control map and evidence are scoped to them. **Verify:** Confirm the in-scope workloads and the EU SIT set with stakeholders; run `GDPR-Discovery.ps1` to list the SITs and current label/DLP coverage. **Implement:** Define the scope and the EU SIT set before authoring policies; capture it in `GDPR Scope – Record`.

2.5 Data-subject-request (DSR) method decided

Description: The chosen **DSR locate-review-produce** method: **Microsoft Priva Subject Rights Requests** (managed workflow) where Priva is licensed, or **Purview eDiscovery (Standard/Premium) / content search** as the locate method where it is not. **Why:** GDPR access/erasure/portability rights (Art. 15/17/20) have a one-month clock; the method must be decided and wired before a request arrives. Availability depends on Priva/eDiscovery licensing — verify. **Verify:** Purview → **eDiscovery** (content search available) and, if licensed, the **Priva** portal → **Subject Rights Requests**. Run `GDPR-Discovery.ps1`. **Implement:** Decide the method with privacy/legal; document it in the DSR runbook (Implementation Step 7). Erasure/production **decisions** remain privacy/legal calls — the tooling locates and produces, it does not decide.

2.6 Compliance, privacy, records & legal stakeholders + ROPA source

Description: Named **compliance, privacy (DPO), records, security, and legal** owners, and the source of the **records of processing activities (Art. 30)**, lawful-basis register, and retention schedules the configuration must satisfy. **Why:** GDPR applicability, lawful basis, ROPA content, DPIA outcomes, and retention durations are **their** determinations, not technical defaults; several mapped capabilities (Insider Risk, Communication Compliance) carry HR/privacy sensitivity. **Verify:** Confirm the DPO/owners, the ROPA source, the lawful-basis register, and the retention schedule. **Implement:** Identify the owners and capture the requirements in `GDPR Scope – Record` before configuring.

2.7 Audit logging enabled (accountability evidence)

Description: Microsoft Purview **Audit** (unified audit log) is turned on so activity is captured for accountability (Art. 5(2)) and breach investigation (Art. 33). **Why:** The evidence register and coverage report read audit/activity data; without it the audit control has no proof. **Verify:** Purview → **Audit**; searching returns results. Run `GDPR-EvidenceReport.ps1`. **Implement:** Turn on auditing in the Purview **Audit** solution; allow time for events to populate.

2.8 Pilot scope and change control

Description: A Microsoft Entra security group of pilot users/locations (`GDPR - Pilot Scope`) and a documented **change-control / rollback** process for any high-impact control switched to enforce (DLP to enforce, a retention policy that deletes content). **Why:** Every mapped high-impact control is piloted in **simulation/test** before enforcement; enforce-mode DLP can block work and retention deletion is irreversible. **Verify:** Entra → **Groups**; `GDPR - Pilot Scope` exists. A change ticket exists with an approver, a pilot scope, and a documented rollback. Run `GDPR-Set-Scope.ps1 -WhatIf`. **Implement:** Build the pilot group with `GDPR-Set-Scope.ps1`; record the change and rollback and get approval before enforcing anything.

Checklist

- Compliance licensing (Compliance Manager + **GDPR template**; E5/E5 Compliance for premium controls; **Priva** for managed SRR) — `GDPR-Discovery.ps1`
- Least-privilege Compliance Manager + Purview roles with **separation** — `GDPR-Discovery.ps1` → `GDPR Roles – Separation Evidence`
- In-scope **GDPR assessment template** selected with compliance/privacy
- Scope: EU personal-data workloads + **EU sensitive-information types** captured → `GDPR Scope – Record`
- **DSR method** decided (Priva SRR or eDiscovery/content search)
- Compliance/privacy (DPO)/records/legal stakeholders + **ROPA / lawful-basis / retention** source named
- Purview **audit logging** enabled — `GDPR-EvidenceReport.ps1`
- Pilot scope `GDPR - Pilot Scope` + change control / rollback — `GDPR-Set-Scope.ps1`

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires (E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names (e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

• **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.
- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with stakeholders.
- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal** stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).
- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements, not technical defaults; several capabilities have HR/legal sensitivity.
- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.
- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.
- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.
- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Microsoft Purview GDPR Compliance Program

Follow these steps **in order**, primarily in the **Microsoft Purview portal** (`https://purview.microsoft.com`) and (for the managed DSR workflow) the **Microsoft Priva** portal.

> ***Model:** Baseline the posture and roles, design the article-to-control map with compliance/privacy/legal, create the GDPR assessment and evidence register, wire the DSR method, and **pilot every high-impact technical control in simulation/test** before enforcing — validating each on `GDPR - Pilot Scope` before you expand. Pattern: **Assess** → **Design** → **Configure** → **Pilot (simulate)** → **Validate** → **Expand**.*
>
> ***Determinations stay with the business.** GDPR applicability, lawful basis, ROPA (Art. 30) content, DPIA (Art. 35) outcomes, retention schedules, and evidence adequacy are **compliance/privacy/legal** calls. This guide configures the method and collects the evidence; it does not make the ruling.*

The named objects created below are reused verbatim in Testing, Troubleshooting, and the scripts:

Object	Name
GDPR assessment (pilot → production)	`GDPR Assessment – Regulation – Pilot`, `GDPR Assessment – Regulation – Production`
Article → control map	`GDPR Control Map – Articles`
Action plan / evidence register	`GDPR Action Plan – Pilot`, `GDPR Evidence – Register`
Scope / owners record	`GDPR Scope – Record`
Role-separation evidence	`GDPR Roles – Separation Evidence`
Sensitivity label	`Sensitivity Label - Personal Data (GDPR) - All Users`
Auto-labeling policy	`Auto-Label - EU Personal Data - Pilot`
DLP policy	`DLP Policy - EU Personal Data - Audit` (renamed `... - Enforce` at the gate)
Retention label	`Retention Label - Personal Data - Storage Limitation`
DSR access search (content-search method)	`DSR - Data Subject Access - Search`
Posture report	`GDPR Posture – Report`

Step 1 — Baseline the posture and roles (Assess)

1. Confirm licensing (Requirement 2.1) and that the **GDPR** assessment template is available in Purview → **Compliance Manager** → **Assessment templates**.

1. Run `GDPR-Discovery.ps1` to capture the current state: existing labels, DLP policies (and mode), retention policies, the **EU personal-data sensitive-information types**, and the Purview **role groups** and their members.

1. Confirm least-privilege **role separation** (Requirement 2.2) and save the role snapshot as `GDPR Roles – Separation Evidence`.

1. **Gate:** licensing confirmed, GDPR template visible, roles separated. If the template is missing, re-check the plan (Requirement 2.1) before proceeding.

Step 2 — Design the scope and the article-to-control map (Design)

1. With compliance/privacy (DPO), records, and legal, confirm the **scope** (workloads holding EU personal data, the EU SIT set) and record it as `GDPR Scope – Record`.

1. Build `GDPR Control Map – Articles` — map each in-scope GDPR obligation to the Purview control that evidences it. A common baseline:

GDPR obligation	Purview control (evidence)
Art. 5(1)(f) / 32 — integrity & confidentiality, security of processing	**Sensitivity labels** (+ encryption), **DLP** over EU personal data, access controls
Art. 5(1)(e) — storage limitation	**Data lifecycle / retention** labels & policies; disposition review
Art. 5(2) — accountability	**Audit** (unified audit log); Compliance Manager evidence register
Art. 15 / 20 — access & portability	**DSR method**: Priva SRR or eDiscovery/content search
Art. 17 — erasure	**DSR** locate + **retention/disposition** (execution deferred to privacy/legal)
Art. 25 — data protection by design & default	**Default/mandatory labeling**, DLP defaults, retention defaults
Art. 30 — records of processing	Documentation (ROPA is a legal artifact; Purview evidences the technical controls)
Art. 33 / 34 — breach notification	**Audit**, DLP alerts, **Insider Risk** signals (where scoped)

1. Applicability, lawful basis, and ROPA content are the stakeholders' determinations — capture the decisions, not assumptions.

Step 3 — Create the pilot GDPR assessment (Configure)

1. Purview → **Compliance Manager** → **Assessments** → **Add assessment**.
2. Choose the **GDPR** template (and any overlay, e.g. **ISO 27701**, where entitled).
3. **Name:** `GDPR Assessment – Regulation – Pilot`. Assign the **group/scope** and create it.
4. The assessment now lists **improvement actions**, each with a score impact, an owner field, an implementation status, a test status, and an evidence slot.

Step 4 — Build the action plan and evidence register

1. In `GDPR Assessment – Regulation – Pilot`, assign each improvement action an **owner** and a target date — this is `GDPR Action Plan – Pilot`.
1. Create the **evidence register** `GDPR Evidence – Register` — for each mapped control, record the owner, implementation status, test status, and the proof location (policy name, audit export, screenshot, or `GDPR-EvidenceReport.ps1` CSV).
1. Enable **automatic testing** where eligible: Purview → **Compliance Manager** → **Settings** → turn on automatic testing of Microsoft-managed actions (`GDPR Automatic Testing – Setting`). Only eligible actions auto-test; the rest are manual — verify availability.

Step 5 — Configure the personal-data protection controls (pilot in simulation/test)

> *Each high-impact control below is **referenced** by the program and evidenced here; it is piloted in **simulation/test** on `GDPR - Pilot Scope` before enforcement. Where the organization already runs the GDPR DLP pack or a label taxonomy, **reuse and evidence** it rather than re-creating it.*

1. **Sensitivity label.** Purview → **Information Protection** → **Sensitivity labels** → **Create a label** → `Sensitivity Label - Personal Data (GDPR) - All Users` (scope **Items**; configure encryption if the classification requires it). Publish it to `GDPR - Pilot Scope` via a label policy.
1. **Auto-labeling (simulation). Information Protection** → **Auto-labeling** → **Create** → `Auto-Label - EU Personal Data - Pilot`; condition = the **EU personal-data sensitive-information types** (Requirement 2.4); apply the label above; choose **Run policy in simulation mode** — do **not** turn it on. Review matches before activating.
1. **DLP in audit. Data Loss Prevention** → **Policies** → **Create** → `DLP Policy - EU Personal Data - Audit; locations = Exchange, SharePoint, OneDrive, Teams, Devices (as licensed), scoped to GDPR - Pilot Scope`; rule matches the EU personal-data SITs and/or the label; action = **audit only** (policy tips on, no block); **Run the policy in test mode**.
1. **Retention (storage limitation). Data Lifecycle Management** → **Retention labels** → **Create** →

`Retention Label - Personal Data - Storage Limitation` (duration/end action **from the retention schedule** — a records/legal input, not a guess); use **disposition review** so nothing is auto-deleted unreviewed. Publish/auto-apply to the pilot scope.

Step 6 — Pilot and tune (the audit gate)

1. Let the audit-mode DLP and simulation auto-labeling run against `GDPR - Pilot Scope` for the agreed

window.

1. Review matches in Purview → **Data Loss Prevention** → **Alerts** / **Activity explorer** and the

auto-labeling **Simulation**; run `GDPR-EvidenceReport.ps1` for a coverage + DLP-event summary.

1. Tune out false positives (confidence levels, instance counts, exceptions).

2. **Gate:** only when the audit shows the controls match real EU personal data and not routine work

do you promote to enforce (Step 8). If still noisy, keep tuning — do not enforce.

Step 7 — Wire the DSR (data-subject-request) method

1. **If Priva is licensed:** Priva portal → **Subject Rights Requests** → **Create request** — configure

the request type (access/export/tag for follow-up), the data subject, and the connectors; use it as the managed locate-review-produce workflow.

1. **If Priva is not licensed:** use Purview **eDiscovery (Standard/Premium)** / content search as the

locate method — create a content search `DSR - Data Subject Access - Search` keyed on the data subject's identifiers across the in-scope workloads, review the results, and export.

1. Document the **DSR runbook**: intake → verify identity → locate (`DSR - Data Subject Access -

Search or Priva SRR) → review → privacy/legal decision → produce/erase → record in GDPR Evidence – Register`. **Erasure/production decisions remain privacy/legal** — the tooling locates and produces, it does not decide.

Step 8 — Promote high-impact controls to enforce (after the gate)

1. **DLP** → **enforce.** Open `DLP Policy - EU Personal Data - Audit` → **Edit**; rename to

`DLP Policy - EU Personal Data - Enforce`; change the action to **Block** (or **Block with override**) as the business requires; **Turn the policy on** for the pilot scope first.

1. **Auto-labeling** → **on.** After the simulation is clean, turn `Auto-Label - EU Personal Data - Pilot`

on (out of simulation).

1. **Rollback (if needed):** set the DLP policy back to **Test mode**, turn auto-labeling back to

simulation, or disable the retention policy. Deletion is irreversible — validate first.

Step 9 — Validate

1. Complete the Testing Guide against `GDPR - Pilot Scope`.
2. Run `GDPR-Validation.ps1` (label published, DLP present + mode, retention present, audit on) and

`GDPR-EvidenceReport.ps1` (classification + DLP-event coverage; audit sample).

1. Run a **test DSR** end to end (Step 7 method) and record it in `GDPR Evidence – Register`.
2. **Gate:** all pass/fail gates in the Testing Guide met; evidence recorded for each mapped control.

Step 10 — Report and expand

1. Produce `GDPR Posture – Report` from Compliance Manager (score, per-action status, evidence) plus

the `GDPR-EvidenceReport.ps1` coverage output.

1. Promote the assessment to `GDPR Assessment – Regulation – Production`; widen the label policy, the

DLP enforce policy, and the retention policy from `GDPR - Pilot Scope` to broader groups (or **All users / All locations**) once the pilot passes.

1. Re-validate each expansion with `GDPR-Validation.ps1` and `GDPR-EvidenceReport.ps1`; run the

maintenance cadence (re-score, re-test, refresh evidence) on a defined schedule.

Order of operations

```
Baseline + roles → scope + article map → GDPR assessment (pilot) → action plan + evidence register → personal-data controls (simulation/audit) → audit gate → DSR method wired → enforce (after gate) → validate + test DSR → report + expand
```

5. Testing Guide — Microsoft Purview GDPR Compliance Program

Run after the pilot assessment and controls are configured on `GDPR - Pilot Scope` (Implementation Steps 3–7), **before** the audit gate (Step 6), and again after each expansion. Each test states what to **do** and the **expected** result; the pass/fail gate is at the end.

Test 1 — GDPR assessment created and scored

Do: Purview → **Compliance Manager** → **Assessments** → open `GDPR Assessment – Regulation – Pilot`. **Expected:** The assessment exists against the **GDPR** template, shows a **Compliance Score**, and lists improvement actions with owner / implementation status / test status / evidence slots.

Test 2 — Roles separated (least privilege)

Do: Purview → **Settings** → **Roles and scopes** → **Role groups**, or run `GDPR-Discovery.ps1` (role report). **Expected:** The mapped roles are assigned least-privilege and HR/privacy-sensitive roles (Insider Risk, Communication Compliance) are held by **separate** owners — captured as `GDPR Roles – Separation Evidence`.

Test 3 — Article-to-control map complete

Do: Review `GDPR Control Map – Articles` and `GDPR Evidence – Register`. **Expected:** Every in-scope obligation maps to a named Purview control with an owner and an evidence location; no in-scope obligation is unmapped.

Test 4 — Personal-data label published and applies

Do: As a pilot user in Word/Outlook, open the **Sensitivity** button; apply `Sensitivity Label - Personal Data (GDPR) - All Users` to a test document. Or run `GDPR-Validation.ps1`. **Expected:** The label appears via its label policy and (if encryption is configured) protects the document per its permissions.

Test 5 — Auto-labeling simulation matches EU personal data

Do: Purview → **Information Protection** → **Auto-labeling** → open `Auto-Label - EU Personal Data - Pilot` → **Simulation**. **Expected:** The simulation lists items containing **EU personal-data sensitive-information types** (e.g. EU National Identification / Passport / Tax ID numbers) and does not flag routine, non-personal content.

Test 6 — DLP is auditing (before the gate)

Do: As a pilot user, email a test message containing a fake **EU personal-data identifier** to an external address; check Purview → **Data Loss Prevention** → **Alerts** / **Activity explorer**. Or run `GDPR-EvidenceReport.ps1`. **Expected:** `DLP Policy - EU Personal Data - Audit` records the match (policy tip shown, no block) — the audit gate has data to review.

Test 7 — DLP enforces (after the gate)

Do: After Implementation Step 8, repeat Test 6 against `DLP Policy - EU Personal Data - Enforce`. **Expected:** The action now blocks (or blocks-with-override) per the enforce rule; the event is logged.

Test 8 — Retention (storage limitation) applied

Do: Apply `Retention Label - Personal Data - Storage Limitation` to a test item and attempt to delete it before the period. Or run `GDPR-Validation.ps1`. **Expected:** The item is retained/dispositioned per the schedule; disposition review holds deletion for review rather than auto-deleting.

Test 9 — DSR method locates a data subject's data

Do: Run the DSR method from Implementation Step 7 — a Priva **Subject Rights Request**, or the content search `DSR - Data Subject Access - Search` keyed on a test subject's identifiers. **Expected:** The request/search returns the test subject's personal data across the in-scope workloads; the run is recorded in `GDPR Evidence – Register`. (The produce/erase **decision** is privacy/legal, not part of this test.)

Test 10 — Audit and coverage evidence

Do: Run `GDPR-EvidenceReport.ps1`. **Expected:** A label inventory, a DLP service/mode matrix, a per-workload DLP-event count, and an audit-log sample — the cross-control evidence for the register.

Test 11 — Posture report produced

Do: Produce `GDPR Posture – Report` (Compliance Manager score + `GDPR-EvidenceReport.ps1` output). **Expected:** A score, per-action status, and evidence summary suitable for compliance/privacy review.

Pass/fail gate

Gate	Requirement
Design pass	Tests 1–3 pass — assessment scored, roles separated, article map complete
Pilot pass	Tests 4–6, 8, 9 pass on `GDPR - Pilot Scope`; DLP audit shows real EU-personal-data matches with acceptable noise
Audit gate	DLP audit reviewed and tuned; only then is Test 7 (enforce) run
Expand pass	Tests 4, 6/7, 8, 10, 11 pass after widening scope beyond the pilot; evidence refreshed in `GDPR Evidence – Register`

6. Troubleshooting Guide — Microsoft Purview GDPR Compliance Program

Common field issues for the GDPR program and how to resolve them. Objects are named verbatim from the Implementation Guide. Most problems are **licensing/cloud gaps**, **replication delay**, or **audit not-yet-tuned** — not step mistakes. When a feature is simply absent, treat it as a plan/cloud gap (Requirement 2.1) and **verify your licensing/tenant** first. Remember the boundary: **GDPR applicability, lawful basis, ROPA (Art. 30), DPIA (Art. 35) outcomes, retention schedules, and evidence adequacy are compliance/privacy/legal determinations** — the tooling configures and evidences, it does not decide.

The GDPR assessment template isn't available in Compliance Manager

• **Symptom:** `GDPR Assessment – Regulation – Pilot` can't be created; the **GDPR** template is missing.

• **Likely cause:** Premium Compliance Manager assessments need **Microsoft 365 E5 / E5 Compliance**; availability varies by cloud.

• **Resolve:** Run `GDPR-Discovery.ps1`; confirm the plan in the M365 admin center; **verify your tenant.** Where the template is absent, evidence the mapped controls against the available baseline and record the gap.

Compliance Score doesn't move / improvement actions don't auto-test

• **Symptom:** After configuring controls, `GDPR Assessment` score or action status doesn't update.

• **Likely cause: Automatic testing** isn't enabled, the action isn't eligible for auto-test, or testing/scan latency.

• **Resolve:** Purview → **Compliance Manager** → **Settings** → enable automatic testing (`GDPR Automatic Testing – Setting`); note only eligible Microsoft-managed actions auto-test — the rest are **manual** and evidenced by hand in `GDPR Evidence – Register`. Allow time to reflect.

The personal-data label doesn't appear for pilot users

• **Symptom:** `Sensitivity Label - Personal Data (GDPR) - All Users` isn't visible in Word/Outlook.

• **Likely cause: Replication delay**, the user isn't in `GDPR - Pilot Scope`, or the client hasn't refreshed.

• **Resolve:** Confirm publication with `GDPR-Validation.ps1`; verify pilot-group membership (`GDPR-Set-Scope.ps1`); restart the Office client; allow propagation before re-publishing.

Auto-labeling simulation shows nothing (or the wrong items)

• **Symptom:** `Auto-Label - EU Personal Data - Pilot` simulation is empty or flags routine content.

• **Likely cause:** Simulation still crawling; the condition doesn't use the **EU personal-data sensitive-information types**; no matching content in the in-scope locations.

• **Resolve:** Let the simulation complete; confirm the rule uses EU SITs (National ID / Passport / Tax ID etc., Requirement 2.4) and applies the correct label; seed a pilot site with test EU-personal-data content; re-run. Never turn the policy on until the simulation is clean.

DLP records nothing in audit

• **Symptom:** No policy tips or Activity-explorer events from `DLP Policy - EU Personal Data - Audit`.

• **Likely cause:** Policy still deploying; **audit logging off** (Requirement 2.7); the location isn't in scope.

• **Resolve:** Confirm auditing is on and returning results; run `GDPR-EvidenceReport.ps1` for the event summary; verify the policy's locations and `GDPR - Pilot Scope` scoping. Allow deployment time.

DLP blocks legitimate work after enforce

• **Symptom:** After Step 8, routine business email/files are blocked.

• **Likely cause:** The policy was promoted before the **audit gate** was clean, or exceptions are missing.

• **Resolve: Rollback** — set `DLP Policy - EU Personal Data - Enforce` back to **Test mode** (audit); tune out false positives (confidence, instance counts, exceptions); re-enforce only after the gate passes.

A DSR (subject rights request) returns nothing / too much

• **Symptom:** The Priva Subject Rights Request or the content search `DSR - Data Subject Access - Search` misses or over-returns the subject's data.

• **Likely cause:** Wrong/insufficient subject identifiers, workloads out of scope, or indexing delay.

• **Resolve:** Broaden the identifiers (email aliases, employee ID, phone); confirm all in-scope workloads are searched; allow indexing time. Record the run in `GDPR Evidence – Register`. **The erase/produce decision is privacy/legal** — the tooling locates and produces, it does not decide.

Retention deletes too much or nothing (storage limitation)

• **Symptom:** `Retention Label - Personal Data - Storage Limitation` behaves unexpectedly.

• **Likely cause:** Policy still propagating; wrong locations; duration/end-action set from a **guess** rather than the retention schedule.

• **Resolve:** Confirm the policy is **On** and scoped (`GDPR-Validation.ps1`); use **disposition review **so nothing auto-deletes unreviewed.** Retention durations are a records/legal determination** — confirm the schedule before activating deletion. Deletion is irreversible.

Role separation looks wrong (HR/privacy-sensitive roles)

• **Symptom:** Insider Risk / Communication Compliance roles held by the same owner as configuration roles.

• **Likely cause:** Over-broad role assignment; least-privilege separation not applied.

• **Resolve:** Purview → **Settings** → **Roles and scopes** → **Role groups**; separate the HR/privacy-sensitive roles from configuration roles; re-capture `GDPR Roles – Separation Evidence` via `GDPR-Discovery.ps1`. Role separation is a control, not a convenience.

Evidence report is empty or partial

• **Symptom:** `GDPR-EvidenceReport.ps1` produces little cross-control evidence.

• **Likely cause:** Audit off; DLP not yet auditing; labels/retention not yet published; read-access gaps.

• **Resolve:** Enable audit (Requirement 2.7); confirm the controls are configured and auditing; re-run after events accumulate; confirm the operator holds the read roles.

PowerShell can't connect or a cmdlet is missing

• **Symptom:** `Connect-IPPSSession` / `Connect-MgGraph` fails or a cmdlet is unavailable.

• **Likely cause:** Modules missing/old, or MFA/modern-auth blocked.

• **Resolve:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser` (and Microsoft.Graph for the scope script); sign in with an MFA-capable Compliance Administrator; retry. A cmdlet still missing after a good connection is a plan/cloud gap — **verify your tenant.**

Escalation & rollback

Situation	Action
DLP enforce disrupts work	Revert to **Test mode** (audit); fix exceptions; re-run the audit gate
Auto-labeling mislabels	Return the policy to **simulation**; fix the rule; re-simulate
Retention deleting wrongly	Disable the retention policy; enable **disposition review**; confirm the schedule with records/legal
Feature genuinely absent	Treat as licensing/cloud gap (Req 2.1) — **verify your licensing/tenant**
Applicability / lawful basis / ROPA / DPIA / erasure question	**Determination deferred** to compliance/privacy/legal — capture, don't decide

7. Best Practices — Microsoft Purview GDPR Compliance Program

• **Map before you build.** Start from `GDPR Control Map – Articles` — decide which Purview control

evidences each in-scope obligation *first*, so every configuration traces to a GDPR article and no obligation is left unmapped. Evidence once, score many via Compliance Manager's shared controls.

- **Keep determinations with the business.** Applicability, lawful basis, ROPA (Art. 30) content, DPIA (Art. 35) outcomes, retention schedules, and erasure decisions are **compliance/privacy/legal** calls. Configure the method and collect the proof; never let the tool make the ruling.
- **Separate the sensitive roles.** Give Insider Risk and Communication Compliance to **different** owners than the general operator, and keep everything least-privilege. The separation is both a control and GDPR accountability evidence — capture it in `GDPR Roles – Separation Evidence`.
- **Simulate and audit before you enforce.** Run auto-labeling in **simulation** and every DLP policy in **test/audit** first; review matches, tune false positives with confidence levels and instance counts, and only then promote to enforce. A blocked-work storm is the fastest way to lose trust.
- **Name every object by purpose and stage.** Use `<Purpose> – <Scope> – <Stage>` (rename `DLP Policy - EU Personal Data - Audit` to `... - Enforce` at the gate) so the portal shows exactly where each control is in its lifecycle and the docs, scripts, and evidence all agree.
- **Wire the DSR method before a request arrives.** Decide Priva SRR vs eDiscovery/content search up front, write the intake→locate→review→decide→produce runbook, and run a **test DSR** so the one-month clock (Art. 15/17/20) never starts on an untested process.
- **Retention from a schedule, not a guess.** Set `Retention Label - Personal Data - Storage Limitation` durations from the records/legal schedule, use **disposition review** so nothing is auto-deleted unreviewed, and record the schedule source so storage-limitation (Art. 5(1)(e)) is defensible.
- **Keep audit on and evidence current.** Unified audit logging underpins accountability (Art. 5(2)) and breach investigation (Art. 33). Refresh `GDPR Evidence – Register` on a cadence with `GDPR-EvidenceReport.ps1` so the posture report reflects reality, not a point-in-time snapshot.
- **Verify licensing before assuming a gap.** The GDPR template, premium controls, and Priva SRR are plan-/tenant-gated and the portal evolves — if a capability is absent, confirm the plan with `GDPR-Discovery.ps1` and Requirement 2.1 before concluding the tenant lacks it.
- **Re-score on a schedule and after change.** Re-run the assessment, re-test eligible actions, and refresh evidence periodically and after any tenant change, so `GDPR Posture – Report` stays audit-ready rather than a one-off deliverable.

8. Deliverables Summary — Microsoft Purview GDPR Compliance Program

Documentation

Document	Purpose
Executive Summary	Business case and what's in the box
1. Solution Overview	What the GDPR program is — Compliance Manager scoring, article-to-control mapping, DSR method, and evidence — benefits and limitations
2. Requirements Guide	Every GDPR-specific prerequisite with Verify / Implement-if-missing
Global Requirements (Purview)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered steps: baseline & roles, article map, GDPR assessment, action plan & evidence register, personal-data controls (simulation/audit), DSR method, enforce, validate, expand
5. Testing Guide	Validation procedures with pass/fail gates and the DLP audit gate
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations

PowerShell scripts

Script	What it does
`GDPR-Discovery.ps1`	Reports the tenant's GDPR-relevant posture — labels, DLP policies (and mode), retention, EU personal-data sensitive-information types, audit signal, and Purview role groups (role-separation readiness); read-only
`GDPR-Validation.ps1`	Confirms the named objects are in place — personal-data label published, DLP present (and its mode), retention present, audit on — pass/fail with exit code
`GDPR-EvidenceReport.ps1`	Cross-control evidence: label inventory, DLP service/mode matrix, per-workload DLP-event counts, and an audit-log sample — optionally exported to CSV for `GDPR Evidence – Register`
`GDPR-Remediation.ps1`	Safe remediation of low-risk gaps (default `-WhatIf`) — enables a disabled label/retention policy; **never** auto-enforces DLP (the audit gate is a human decision)
`GDPR-Set-Scope.ps1`	Builds/updates the `GDPR - Pilot Scope` Microsoft Entra security group for piloting and expansion

What the buyer receives

- This implementation guide as a Word document and PDF.
- All five PowerShell scripts in a single ZIP.
- A repeatable program following the model: **Assess → Design → Configure → Pilot (simulate) → Validate → Expand**, with a DLP audit gate before enforce, a wired DSR runbook, and a documented rollback.

Outcome

A GDPR-aligned program in Microsoft Purview — obligations mapped to Purview controls, scored in Compliance Manager, personal-data protection piloted in simulation/audit before it enforces, a DSR method that answers access/erasure/portability requests on the clock, and a centralized evidence register — configured, validated, and **defensible**. GDPR applicability, lawful basis, ROPA content, DPIA outcomes, and evidence adequacy remain compliance/privacy/legal determinations.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

GDPR-Discovery.ps1

Purpose: Connects to Security & Compliance PowerShell and reports the "what exists today" baseline for the GDPR program: sensitivity labels and label policies, DLP policies (with mode: test/audit vs enforce), retention labels/policies, the EU personal-data sensitive-information types available in the tenant, and the Purview role groups + members (role-separation readiness). Compliance Manager assessments are portal-driven and are NOT created here. HOW TO RUN Install-Module ExchangeOnlineManagement -Scope CurrentUser powershell -ExecutionPolicy Bypass -File .\GDPR-Discovery.ps1 Sign in as a least-privilege Compliance Administrator / Compliance Data Administrator. EXPECTED RESULTS Lists of labels (name, priority, encryption), label policies, DLP policies (name + MODE — flags any already enforcing), retention labels/policies, matching EU personal-data SITs, and Purview role groups with member counts. Read-only — makes no changes. .NOTES White-label — Purview Solutions. Read-only. Uses Get-Label / Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy / Get-ComplianceTag / Get-DlpSensitiveInformationType / Get-RoleGroup / Get-RoleGroupMember. > [CmdletBinding()] param()

How to run: Install-Module ExchangeOnlineManagement -Scope CurrentUser powershell -ExecutionPolicy Bypass -File .\GDPR-Discovery.ps1 Sign in as a least-privilege Compliance Administrator / Compliance Data Administrator. EXPECTED RESULTS Lists of labels (name, priority, encryption), label policies, DLP policies (name + MODE — flags any already enforcing), retention labels/policies, matching EU personal-data SITs, and Purview role groups with member counts. Read-only — makes no changes. .NOTES White-label — Purview Solutions. Read-only. Uses Get-Label / Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy / Get-ComplianceTag / Get-DlpSensitiveInformationType / Get-RoleGroup / Get-RoleGroupMember. > [CmdletBinding()] param()

GDPR-EvidenceReport.ps1

Purpose: Produces the cross-control evidence the program records in `GDPR Evidence - Register`: (1) the sensitivity-label inventory (classification / Art. 32 evidence), (2) a DLP service/mode matrix over EU personal data, (3) recent DLP events from the unified audit log grouped by workload (the audit-gate data), and (4) a small audit-log sample proving accountability logging (Art. 5(2)/33) is on. Optionally exports to CSV. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\GDPR-EvidenceReport.ps1 -Days 7 -CsvPath C:\Temp\gdpr-evidence.csv Sign in as a Compliance Administrator when prompted. Requires audit logging enabled (Requirement 2.7) for the event sections to return data. EXPECTED RESULTS A label inventory, a DLP location/mode matrix, a per-workload DLP-event count, and an audit-log sample for the window — optionally saved to CSV for the evidence register. .NOTES White-label — Purview Solutions. Read-only. Uses Get-Label / Get-DlpCompliancePolicy and Search-UnifiedAuditLog (DLP + sample records). > [CmdletBinding()] param([int]$Days = 7, [string]$CsvPath)

How to run: powershell -ExecutionPolicy Bypass -File .\GDPR-EvidenceReport.ps1 -Days 7 -CsvPath C:\Temp\gdpr-evidence.csv Sign in as a Compliance Administrator when prompted. Requires audit logging enabled (Requirement 2.7) for the event sections to return data. EXPECTED RESULTS A label inventory, a DLP location/mode matrix, a per-workload DLP-event count, and an audit-log sample for the window — optionally saved to CSV for the evidence register. .NOTES White-label — Purview Solutions. Read-only. Uses Get-Label / Get-DlpCompliancePolicy and Search-UnifiedAuditLog (DLP + sample records). >

[CmdletBinding()] param([int]$Days = 7, [string]$CsvPath)

GDPR-Remediation.ps1

Purpose: Remediates the low-risk gaps GDPR-Validation.ps1 finds — enabling a published-but-off label policy and enabling a disabled retention policy — WITHOUT ever switching a DLP policy to enforce (the audit gate is a human decision) and without deleting anything. Runs in -WhatIf by default; pass -Apply to make the two safe changes. It only REPORTS DLP policies still in test/audit for the operator to promote manually. HOW TO RUN Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\GDPR-Remediation.ps1 Apply changes: powershell -ExecutionPolicy Bypass -File .\GDPR-Remediation.ps1 -Apply Sign in as a Compliance Administrator when prompted. EXPECTED RESULTS A list of proposed actions (WhatIf) or the applied changes (-Apply). DLP enforce is never automated; retention is enabled but never created or deleted. .NOTES White-label — Purview Solutions. Default is a dry run. Uses Get-/Set-LabelPolicy and Get-/Set-RetentionCompliancePolicy; reads Get-DlpCompliancePolicy. > [CmdletBinding()] param([switch]$Apply, [string]$LabelPolicyName = 'Label Policy - Sensitivity Taxonomy - All Users', [string]$RetentionPolicyName = 'Retention Policy - Personal Data - Storage Limitation') $WhatIf = -not $Apply $mode = $(if($WhatIf){'WHATIF (preview only)'}else{'APPLY'})

How to run: Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\GDPR-Remediation.ps1 Apply changes: powershell -ExecutionPolicy Bypass -File .\GDPR-Remediation.ps1 -Apply Sign in as a Compliance Administrator when prompted. EXPECTED RESULTS A list of proposed actions (WhatIf) or the applied changes (-Apply). DLP enforce is never automated; retention is enabled but never created or deleted. .NOTES White-label — Purview Solutions. Default is a dry run. Uses Get-/Set-LabelPolicy and Get-/Set-RetentionCompliancePolicy; reads Get-DlpCompliancePolicy. > [CmdletBinding()] param([switch]$Apply, [string]$LabelPolicyName = 'Label Policy - Sensitivity Taxonomy - All Users', [string]$RetentionPolicyName = 'Retention Policy - Personal Data - Storage Limitation') $WhatIf = -not $Apply $mode = $(if($WhatIf){'WHATIF (preview only)'}else{'APPLY'})

GDPR-Set-Scope.ps1

Purpose: Creates or updates the Microsoft Entra security group used to pilot and then expand the GDPR program ('GDPR - Pilot Scope') and, optionally, adds a supplied list of pilot users. This is the scope every high-impact control (label, DLP, retention) targets before tenant-wide expansion. Runs in -WhatIf by default; pass -Apply to make changes. It never deletes the group or removes members. HOW TO RUN Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\GDPR-Set-Scope.ps1 Apply (create/update): powershell -ExecutionPolicy Bypass -File .\GDPR-Set-Scope.ps1 -Apply Add members: .\GDPR-Set-Scope.ps1 -Apply -Members user1@contoso.com,user2@contoso.com Sign in with a Groups Administrator (or better) when Connect-MgGraph prompts. EXAMPLE .\GDPR-Set-Scope.ps1 -WhatIf EXPECTED RESULTS Reports whether the group exists and what would change (WhatIf) or creates/updates it (-Apply), then reports membership. Use the group as the pilot scope in the label/DLP/retention policies. .NOTES White-label — Purview Solutions. Default is a dry run. PowerShell 5.1+/7+. Microsoft Graph: Group.ReadWrite.All (+ User.Read.All to resolve members). No credentials in code. > [CmdletBinding()] param([string] $GroupName = 'GDPR - Pilot Scope', [string] $MailNickname = 'gdpr-pilot-scope', [string[]]$Members, [switch] $Apply, [switch] $WhatIf) $doApply = $Apply -and -not $WhatIf $mode = $(if($doApply){'APPLY'}else{'WHATIF (preview only)'})

How to run: Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\GDPR-Set-Scope.ps1 Apply (create/update): powershell -ExecutionPolicy Bypass -File .\GDPR-Set-Scope.ps1 -Apply Add

members: .\GDPR-Set-Scope.ps1 -Apply -Members user1@contoso.com,user2@contoso.com Sign in with a Groups Administrator (or better) when Connect-MgGraph prompts. EXAMPLE .\GDPR-Set-Scope.ps1 -WhatIf EXPECTED RESULTS Reports whether the group exists and what would change (WhatIf) or creates/updates it (-Apply), then reports membership. Use the group as the pilot scope in the label/DLP/retention policies. .NOTES White-label — Purview Solutions. Default is a dry run. PowerShell 5.1+/7+. Microsoft Graph: Group.ReadWrite.All (+ User.Read.All to resolve members). No credentials in code. > [CmdletBinding()] param([string] $GroupName = 'GDPR - Pilot Scope', [string] $MailNickname = 'gdpr-pilot-scope', [string[]]$Members, [switch] $Apply, [switch] $WhatIf) $doApply = $Apply -and -not $WhatIf $mode = $(if($doApply){'APPLY'}else{'WHATIF (preview only)'})

GDPR-Validation.ps1

Purpose: Verifies the objects this program deploys are present: the personal-data label policy is published, the EU-personal-data DLP policy exists (and reports its mode so you can see whether it has passed the audit gate into enforce), and the storage-limitation retention policy exists and is enabled. Pass/fail per the Testing Guide — read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\GDPR-Validation.ps1 Sign in as a Compliance Administrator when prompted. Optionally pass -LabelPolicyName / -DlpPolicyName / -RetentionPolicyName to match your renamed objects. EXPECTED RESULTS "VALIDATION PASSED" when the label policy is enabled, the DLP policy is present, and the retention policy is enabled. Exit code 0 on pass, 1 on any gap. .NOTES White-label — Purview Solutions. Read-only. Uses Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy. > [CmdletBinding()] param([string]$LabelPolicyName = 'Label Policy - Sensitivity Taxonomy - All Users', [string]$DlpPolicyName = 'DLP Policy - EU Personal Data', [string]$RetentionPolicyName = 'Retention Policy - Personal Data - Storage Limitation')

How to run: powershell -ExecutionPolicy Bypass -File .\GDPR-Validation.ps1 Sign in as a Compliance Administrator when prompted. Optionally pass -LabelPolicyName / -DlpPolicyName / -RetentionPolicyName to match your renamed objects. EXPECTED RESULTS "VALIDATION PASSED" when the label policy is enabled, the DLP policy is present, and the retention policy is enabled. Exit code 0 on pass, 1 on any gap. .NOTES White-label — Purview Solutions. Read-only. Uses Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy. > [CmdletBinding()] param([string]$LabelPolicyName = 'Label Policy - Sensitivity Taxonomy - All Users', [string]$DlpPolicyName = 'DLP Policy - EU Personal Data', [string]$RetentionPolicyName = 'Retention Policy - Personal Data - Storage Limitation')